// MLSECOPSHUB · READINESS CHECKLIST

EU AI Act security checklist

Framework: EU AI Act (Regulation (EU) 2024/1689)
Official source: https://eur-lex.europa.eu/eli/reg/2024/1689/oj
Online version and control mapping: https://mlsecopshub.com/readiness/eu-ai-act
Last updated 2026-09-08. 27 items. Obligations are paraphrased; engineering guidance, not legal advice.

Scope and classification

- [ ] Inventory every AI system and model in production, including third-party APIs and agents embedded in internal tools.
- [ ] Classify each system against Article 5 prohibited practices, Annex III high-risk use cases and Annex I product legislation.
- [ ] Record whether your organization is a provider, deployer, importer or distributor for each system.
- [ ] Flag general-purpose AI models you train or substantially modify; check the systemic-risk compute threshold.
- [ ] Assign an accountable owner per high-risk system and a compliance deadline based on the phased application dates.

Model supply chain

- [ ] Block pickle-based model formats in CI; allow Safetensors, ONNX or GGUF only.
- [ ] Run PyTorch 2.6 or later, patched for CVE-2025-32434, and keep torch.load weights_only=True everywhere.
- [ ] Sign every model artifact at build time and verify the signature at load time.
- [ ] Record provenance for each model: source repository, commit, training data hashes, base model and license.
- [ ] Generate an AI bill of materials (models, datasets, libraries) with every release.
- [ ] Scan third-party models from public hubs before use and quarantine them until scanned.

Data governance and documentation

- [ ] Maintain dataset cards with source, license, collection date and known biases.
- [ ] Hash and version every training, validation and test dataset.
- [ ] Screen training data for poisoning and label manipulation before every training run.
- [ ] Generate Annex IV technical documentation from the pipeline, not by hand.
- [ ] Keep instructions for use current, including documented failure modes for LLM components.

Robustness, cybersecurity and testing

- [ ] Run a prompt-injection and jailbreak test suite against every release of an LLM-based system.
- [ ] Test adversarial-example and model-evasion resistance for classifiers used in high-risk decisions.
- [ ] Enforce least-privilege scopes for agent tools and MCP servers; deny by default.
- [ ] Require human confirmation for agent actions that move money, change access or send external messages.
- [ ] Test kill switch and model rollback in staging at least quarterly.
- [ ] Store model weights with access logging and hardware-backed keys.

Logging, monitoring and incidents

- [ ] Log model version, prompt template version, tool calls and human overrides for every inference in a high-risk system.
- [ ] Set log retention to at least six months and document the retention policy.
- [ ] Monitor injection attempt rates, tool-call anomalies and evaluation drift in production.
- [ ] Define AI-specific serious-incident triggers and map them to the Article 73 reporting clock.
- [ ]

Run a tabletop exercise for a model-compromise scenario and record the outcome.

```
Have this run against your pipeline: https://mlsecopshub.com/services
Book a 30-minute assessment call: https://mlsecopshub.com/contact
```